



The Web3 Security Labs

SMART CONTRACT AUDIT REPORT

YoloArc Consolidated Security Audit Report

July 14, 2026

@0xTheWeb3Labs | theweb3security.com

The Web3 Security Labs focus on Web3 project attack and defense, Web3 project audit and Web3 project security analysis.

Consolidated Security Audit Report

Generated on: July 14, 2026 · Project: **yoloarc-contracts** (YoloArc sports-betting on-chain contracts)

Executive Summary

This report consolidates the security findings raised during the review of the **YoloArc** smart-contract suite (YoloToken + allocation managers, deployed behind transparent upgradeable proxies on BNB Chain) together with the project team's disposition of each item. A total of **81 findings (BUG-001 – BUG-081)** were raised across correctness, access control, tokenomics/AMM interaction, upgradeability, and code quality.

0

CRITICAL

8

HIGH

28

MEDIUM

22

LOW

23

INFO

Resolution status: ✓ Fixed: **16** | △ Acknowledged / accepted (by design): **56** | ✗ Disputed: **1** | Open (pending triage): **8**

Overall security posture: The core custody and reward-accounting issues that were confirmed exploitable have been fixed (unsafe transfers, non-upgradeable reentrancy guard, missing withdrawal paths, unreachable pause, split-claim threshold bypass, missing storage gap). The large body of remaining items is **accepted risk** the team classifies as intentional tokenomics design or as mitigated by privileged, off-chain-controlled entry points.

Dominant residual risk — centralization. Most accepted findings rely on the same mitigation: the sensitive entry point is callable only by the project-controlled **contractCaller** / owner, and dangerous parameters (batch sizes, balances, invite depth) are bounded off-chain. Security therefore depends heavily on the integrity of the privileged backend caller and owner keys.

Protocol Overview

Purpose. YoloArc is a sports-betting ecosystem built around a fee/tax-bearing ERC-20 (**YoloToken**) plus a set of allocation and treasury managers. Token mechanics include a 300 bps sell fee, a tiered fall (down) tax, a whitelist that bypasses fees, a Fomo reward pool, and a price reference (**latestChoPrice**) used to trigger the fall tax.

Architecture. A token + allocation-manager two-layer design, entirely behind **TransparentUpgradeableProxy** . Each core contract has a dedicated Storage contract with a **__gap** reservation for upgrade-safe storage. An off-chain caller layer (**yolo-contracts-caller**) drives the privileged business functions.

- **YoloToken** → mainPair (PancakeV2) → SwapHelper → PancakeV2/V3 Router
- **UserManager** — inviter / referral binding, staking (**onlyCaller**)
- **CardManager** — NFT card allocation / sales (upgradeable)
- **LpManager** — LP allocation (upgradeable)
- **FomoTreasureManager** — Fomo reward pool distribution
- **SwapHelper / TradeSlippage (Marking)** — swap wrapper + slippage / price-impact control

Audit Scope

In scope: all contracts in **src/** , with focus on:

- **token/YoloToken.sol** , **token/YoloTokenStorage.sol**
- **core/UserManager.sol** , **core/FomoTreasureManager.sol**
- **token/allocation/CardManager.sol** , **token/allocation/LpManager.sol**
- **utils/SwapHelper.sol** , **utils/TradeSlippage.sol** , **NftTokenManager.sol**
- Storage contracts and **script/** proxy deployment (**__gap** layout, initializer wiring)

Solidity version: 0.8.20 (**evm_version=prague** , **via_ir** + optimizer). **Out of scope:** the off-chain **yolo-contracts-caller** backend, PancakeSwap routers/factory, and third-party (OpenZeppelin) libraries.

Roles & Trust Assumptions

- **Owner (superuser):** configures role addresses (`operator` , `stakingManager` , `fomoTreasureAddress` , `predictionContract` , ...), toggles `isOpenBuy` / `isOpenSell` , upgrades proxies, and may renounce ownership.
- **contractCaller (backend / hot wallet):** the only caller permitted for core business functions on `UserManager` and the managers (`onlyCaller`). Batch sizes and inputs are bounded here off-chain.
- **Trust failure:** the system assumes the owner and `contractCaller` keys are secure. If compromised, an attacker could exploit the accounting-inflation, unbounded-loop, and permissionless-drain findings that are currently considered mitigated by access control.

Findings Summary Table

ID	SEVERITY	TITLE	AFFECTED CONTRACT(S)	IMPACT	STATUS
[BUG-001]	High	Flash-Loan / Spot-Price Oracle Manipulation Bypasses Fall Tax	YoloToken.sol, TradeSlippage.sol	Fee avoidance	Acknowledged
[BUG-002]	Medium	Manual Oracle Update Can Lock Tax Rate ("Death Spiral")	YoloToken.sol	Trading suppressed	Acknowledged
[BUG-003]	Low	stakingAndUseYolo Per-Unit Swap Loop Is Gas-Inefficient	UserManager.sol	High gas cost	Acknowledged
[BUG-004]	Low	block.timestamp + N Deadline Pattern Is a No-Op vs MEV	UserManager.sol, SwapHelper.sol	MEV delay	Acknowledged
[BUG-005]	Medium	LpManager.addLiquidity Zero Slippage -> Sandwich	LpManager.sol	Economic loss	Acknowledged
[BUG-006]	Medium	CardManager Uses Non-Upgradeable ReentrancyGuard Under Proxy	CardManager.sol	Storage/guard corruption	Fixed
[BUG-007]	Medium	FomoTreasureManager.claimReward Uses Unsafe transfer	FomoTreasureManager.sol	Silent failure / desync	Fixed
[BUG-008]	Low	SwapHelper.swapV2 Never Resets Approval -> Infinite Allowance	SwapHelper.sol	Approval risk	Acknowledged
[BUG-009]	Medium	swapBurn Uses Total Contract USDT, Not Isolated From Stakes	Marking/TradeSlippage.sol	Accounting mix	Acknowledged
[BUG-010]	Medium	Marking.getUsdtTokenAmount Absolute-Balance Check Can Be Bypassed	Marking/TradeSlippage.sol	Logic bypass	Acknowledged
[BUG-011]	Medium	YoloToken.initialize Pair-Creation DoS via Pre-Creation	YoloToken.sol	Init DoS	Acknowledged
[BUG-012]	Low	Root Inviter Cannot Join Public Referral System	UserManager.sol	Cold-start edge case	Acknowledged
[BUG-013]	Low	Parent Upgradeable Contracts of CardManager/UserManager Not Initialized	CardManager.sol, UserManager.sol	Init hygiene	Acknowledged
[BUG-014]	Medium	ERC-721 NFTs Can Be Permanently Locked in NftTokenManager	NftTokenManager.sol	Asset lock	Acknowledged
[BUG-015]	Medium	claimRefundingAmount Volume Threshold Bypass via Split Claims	UserManager.sol	Threshold bypass	Fixed
[BUG-016]	Medium	AMM-Donation Disguised as Liquidity Fully Evades Tax	YoloToken.sol	Tax evasion	Open
[BUG-017]	Medium	Native ETH Permanently Locked in NftTokenManager	NftTokenManager.sol	Asset lock	Fixed
[BUG-018]	High	recycle() Pulls Tokens From Pair Without LP Consent, Breaks AMM Invariant	YoloToken.sol	Value transfer from LPs	Acknowledged

ID	SEVERITY	TITLE	AFFECTED CONTRACT(S)	IMPACT	STATUS
[BUG-019]	Medium	Marking._sellAndRecycle Uses Inflated Input and Wrong Swap Function	Marking/TradeSlippage.sol	Incorrect swap	Open
[BUG-020]	High	Centralized openBuy / openSell Switches -> Honey_pot Risk	YoloToken.sol	Honey_pot	Acknowledged
[BUG-021]	High	usedStakedYoloBalance Never Written -> Permanent Accounting Error	UserManager.sol	Accounting corruption	Acknowledged
[BUG-022]	High	claimReward Shares fundingBalance Across Reward Types -> Cross-Drain	FomoTreasureManager.sol	Cross-type drain	Acknowledged
[BUG-023]	Medium	updateFundingBalance Inflates Accounting With No Deposit	FomoTreasureManager.sol / CardManager.sol	Accounting inflation	Acknowledged
[BUG-024]	High	_consumeStakeForUsage Consumes Locked Shares Before unlockAt	UserManager.sol	Premature unlock	Acknowledged
[BUG-025]	Low	bindInviterBatch Parameter Shadows State Variable inviters	UserManager.sol	Shadowing	Acknowledged
[BUG-026]	Medium	NftTokenManagerStorage Missing __gap	NftTokenManagerStorage.sol	Upgrade safety	Fixed
[BUG-027]	Medium	calculateSellAmount / calculateBuyAmount k = rY*rU Overflow Risk	Marking/TradeSlippage.sol	Overflow	Open
[BUG-028]	Medium	CardManager.withdraw No Rollback on Failed Native Transfer	CardManager.sol	Accounting desync	Fixed
[BUG-029]	Medium	CardManager.withdrawErc20 Does Not Decrement fundingBalance	CardManager.sol	Accounting	Acknowledged
[BUG-030]	Low	LpManager / FomoTreasureManager Never Initialize PausableUpgradeable	LpManager.sol, FomoTreasureManager.sol	Pause unusable	Acknowledged
[BUG-031]	Info	CardManager Redundant ERC721URIStorageUpgradeable Inheritance	CardManager.sol	Gas	Acknowledged
[BUG-032]	Medium	CardManager.depositRewardErc20 Allows Arbitrary feePayer	CardManager.sol	Approval abuse	Acknowledged
[BUG-033]	Medium	FomoTreasureManager Native ETH Lock	FomoTreasureManager.sol	Asset lock	Fixed
[BUG-034]	Medium	FomoTreasureManager.withdrawErc20 Does Not Decrement fundingBalance	FomoTreasureManager.sol	Accounting	Acknowledged
[BUG-035]	Low	CardManager.buyCard / buyCards Bypass Pause Mechanism	CardManager.sol	Pause bypass	Acknowledged
[BUG-036]	Medium	UserManager.setYoloToken Breaks Staking Accounting on Migration	UserManager.sol	Migration risk	Acknowledged
[BUG-037]	Low	NFT Metadata URI Immutable; Unrecoverable if IPFS Link Breaks	CardManager.sol / NftTokenManager.sol	Metadata risk	Acknowledged
[BUG-038]	Low	Single-Step Ownership Transfer Risk	Multiple	Ownership loss	Acknowledged

ID	SEVERITY	TITLE	AFFECTED CONTRACT(S)	IMPACT	STATUS
[BUG-039]	Info	Authorized-Caller Update Emits No Event	Multiple	Observability	Acknowledged
[BUG-040]	Low	No Generic Rescue for Mistakenly-Sent ERC-20	Multiple	Stuck tokens	Open
[BUG-041]	Medium	distributeReward Unbounded Array Loop -> Block-Gas DoS	FomoTreasureManager.sol	DoS	Acknowledged
[BUG-042]	Low	depositRewardErc20 Incompatible With Fee-on-Transfer Tokens	CardManager.sol	Accounting	Acknowledged
[BUG-043]	Medium	bindRootInviter Allows Self-Binding -> Invite-Tree Loop	UserManager.sol	Infinite loop	Acknowledged
[BUG-044]	Info	_takeSellFee Emits No Event	YoloToken.sol	Observability	Acknowledged
[BUG-045]	Low	setConfig Does Not Revoke Old Router Approval	SwapHelper.sol / config	Approval residue	Open
[BUG-046]	Medium	claimRefundingAmount Does Not Consume userTradingVolume	UserManager.sol	(disputed)	Disputed
[BUG-047]	High	validatorMineClaim Permissionless for Any Token -> Drain Risk	Marking/TradeSlippage.sol	Drain	Acknowledged
[BUG-048]	Medium	getTradeType Precision Loss; Sell Misjudged as Add-Liquidity	TradeSlippage.sol	Misclassification	Open
[BUG-049]	High	YoloToken.poolAllocate Can Exceed MaxTotalSupply	YoloToken.sol	Supply cap breach	Acknowledged
[BUG-050]	Low	FomoTreasureManager.distributeReward Does Not Verify Token Balance	FomoTreasureManager.sol	Under-funded distro	Acknowledged
[BUG-051]	Medium	Flash-Swap Disguises getTradeType, Bypasses isOpenBuy	YoloToken.sol, TradeSlippage.sol	Lock bypass	Acknowledged
[BUG-052]	Medium	FomoTreasureManager / UserManager Pause Function Unreachable	FomoTreasureManager.sol, UserManager.sol	Pause unusable	Fixed
[BUG-053]	Info	Reentry-Lock Gas Optimization (0->1 vs 1->2)	Multiple	Gas	Open
[BUG-054]	Low	renounceOwnership Can Permanently Disable Protocol Admin	Multiple	Admin loss	Acknowledged
[BUG-055]	Low	_distributeSingleReward Missing Zero-Address Check	FomoTreasureManager.sol	Input validation	Fixed
[BUG-056]	Info	rewardType Has No Upper-Bound Check	FomoTreasureManager.sol	Input validation	Acknowledged
[BUG-057]	Info	TradeSlippage.getTradeType Multi-Hop Semantics Unclear	TradeSlippage.sol	Clarity	Acknowledged
[BUG-058]	Medium	bindInviterBatch / updateUserTradingVolume Unbounded Loop	UserManager.sol	DoS	Acknowledged

ID	SEVERITY	TITLE	AFFECTED CONTRACT(S)	IMPACT	STATUS
[BUG-059]	Info	Redundant allowance / balanceOf Checks Before safeTransferFrom	Multiple	Gas / redundancy	Acknowledged
[BUG-060]	Low	withdraw Unnecessarily payable -> ETH Mis-Send Loss	CardManager.sol	Mis-send	Fixed
[BUG-061]	Info	Inconsistent Solidity Pragma Versions	Multiple	Consistency	Fixed
[BUG-062]	Info	Dead State Variable in YoloTokenStorage	YoloTokenStorage.sol	Code quality	Acknowledged
[BUG-063]	Info	adminFeeVault Unused in CardManagerStorage	CardManagerStorage.sol	Code quality	Acknowledged
[BUG-064]	Low	TradeSlippage.isContract Unreliable During Construction	TradeSlippage.sol	Detection edge case	Acknowledged
[BUG-065]	Info	Commented-Out Transfer Restriction in CardManager	CardManager.sol	Dead code	Acknowledged
[BUG-066]	Low	NftTokenManager.setWithdrawCaller Allows address(0)	NftTokenManager.sol	Config error	Fixed
[BUG-067]	Low	_autoFuckExternal Is external; ABI Exposure and Naming	YoloToken.sol	ABI hygiene	Open
[BUG-068]	Info	setPlatformAddress Duplicates setFomoTreasureAddress	YoloToken.sol	Redundancy	Fixed
[BUG-069]	Info	UserManager.initialize Unnamed/Unused Second Parameter	UserManager.sol	Code quality	Fixed
[BUG-070]	Info	CardManager Has Two ETH Receive Paths	CardManager.sol	Redundancy	Acknowledged
[BUG-071]	Info	SPORTS_USAGE_BPS Constant Unused	Multiple	Dead constant	Acknowledged
[BUG-072]	Info	isSwapFactory Wastes Gas via Self-External Call	TradeSlippage.sol	Gas	Acknowledged
[BUG-073]	Info	Unused view Function in YoloToken	YoloToken.sol	Dead code	Acknowledged
[BUG-074]	Info	Redundant _transferOwnership in YoloToken.initialize	YoloToken.sol	Redundancy	Acknowledged
[BUG-075]	Info	_batchCardPrice Nested Loops Re-Read Storage	CardManager.sol	Gas	Acknowledged
[BUG-076]	Info	CardManager.setContractCaller Inaccurate Error Message	CardManager.sol	Message	Fixed
[BUG-077]	Info	PausableUpgradeable Unused in LpManager	LpManager.sol	Dead inheritance	Acknowledged
[BUG-078]	Info	FomoTreasureManager Error Message Cites Wrong Contract Name	FomoTreasureManager.sol	Message	Fixed

ID	SEVERITY	TITLE	AFFECTED CONTRACT(S)	IMPACT	STATUS
[BUG-079]	Low	TradeSlippage owner Uninitialized -> Admin Funcs Unusable	TradeSlippage.sol	Admin unusable	Acknowledged
[BUG-080]	Info	Marking Uses Handwritten Reentry Lock, Not OZ Guard	Marking/TradeSlippage.sol	Convention	Acknowledged
[BUG-081]	Low	CardManager minAmount Hardcodes 18-Decimal Precision	CardManager.sol	Precision assumption	Acknowledged

Detailed Findings

[BUG-001] Flash-Loan / Spot-Price Oracle Manipulation Bypasses Fall Tax

HIGH

ACKNOWLEDGED

Affected: `YoloToken.sol`, `TradeSlippage.sol`

Description: The fall (down) tax is triggered from a manipulable spot price reference (latestChoPrice / AMM spot). A user can use a flash loan or a large spot-price move to bypass the tiered fall tax (PRICE_DROP_3/6_BPS -> DOWN_TAX_3/6_BPS) when selling.

Impact: Fee avoidance.

Resolution / Team Response: By design. The mechanic intentionally allows users to avoid the fall tax through this path, which the team uses to drive trading volume.

[BUG-002] Manual Oracle Update Can Lock Tax Rate ("Death Spiral")

MEDIUM

ACKNOWLEDGED

Affected: `YoloToken.sol`

Description: updateChoPrice() is updated manually (once per day at 00:00). If price keeps falling, the fall tax stays elevated, suppressing selling and potentially reinforcing a downward spiral.

Impact: Trading suppressed.

Resolution / Team Response: By design. The intent is to suppress selling during declines; updateChoPrice() updates only once a day at 00:00, so this is considered reasonable.

[BUG-003] stakingAndUseYolo Per-Unit Swap Loop Is Gas-Inefficient

LOW

ACKNOWLEDGED

Affected: `UserManager.sol`

Description: stakingAndUseYolo performs swaps one unit at a time in a loop, which is gas-heavy and can degrade execution price versus a single batched swap.

Impact: High gas cost.

Resolution / Team Response: By design. Entries are processed one-by-one so the first staker buys at a lower price; the team accepts the higher gas cost to protect user experience/fairness.

[BUG-004] block.timestamp + N Deadline Pattern Is a No-Op vs MEV

LOW

ACKNOWLEDGED

Affected: `UserManager.sol`, `SwapHelper.sol`

Description: Using block.timestamp + N as a swap deadline offers no protection because the miner/validator controls the timestamp; the deadline is always satisfiable.

Impact: MEV delay.

Resolution / Team Response: Accepted. The parameter is controllable when called off-chain, so callers can integrate their own protection against Pancake-style attacks.

[BUG-005] LpManager.addLiquidity Zero Slippage -> Sandwich

MEDIUM

ACKNOWLEDGED

Affected: `LpManager.sol`

Description: addLiquidity supplies liquidity with zero/min slippage bounds, exposing the transaction to MEV sandwiching.

Impact: Economic loss.

Resolution / Team Response: Access-controlled. The function is permissioned and only used when seeding the base pool, so the team considers it non-exploitable in practice.

[BUG-006] CardManager Uses Non-Upgradeable ReentrancyGuard Under Proxy**MEDIUM****FIXED**Affected: `CardManager.sol`

Description: CardManager runs behind a proxy but inherits the non-upgradeable ReentrancyGuard, whose constructor-set storage is not initialized in the proxy context.

Impact: Storage/guard corruption.

Resolution / Team Response: Fixed. Migrated to the upgradeable ReentrancyGuard.

[BUG-007] FomoTreasureManager.claimReward Uses Unsafe transfer**MEDIUM****FIXED**Affected: `FomoTreasureManager.sol`

Description: claimReward uses raw ERC20 transfer, which can silently fail for non-standard tokens, leaving on-chain accounting out of sync with actual balances.

Impact: Silent failure / desync.

Resolution / Team Response: Fixed. Replaced with SafeERC20 safeTransfer.

[BUG-008] SwapHelper.swapV2 Never Resets Approval -> Infinite Allowance**LOW****ACKNOWLEDGED**Affected: `SwapHelper.sol`

Description: swapV2 grants router approval but never resets it, leaving a standing (potentially unlimited) allowance to the router.

Impact: Approval risk.

Resolution / Team Response: Accepted. Only the exact amount a user supplies is swapped, so the residual approval is not considered a problem.

[BUG-009] swapBurn Uses Total Contract USDT, Not Isolated From Stakes**MEDIUM****ACKNOWLEDGED**Affected: `Marking/TradeSlippage.sol`

Description: swapBurn operates on the contract's entire USDT balance rather than a segregated amount, mixing burn funds with other custody.

Impact: Accounting mix.

Resolution / Team Response: By design. The USDT is proceeds from user token-purchase burns, deposited to the contract periodically; using the full balance is intended.

[BUG-010] Marking.getUsdtTokenAmount Absolute-Balance Check Can Be Bypassed**MEDIUM****ACKNOWLEDGED**Affected: `Marking/TradeSlippage.sol`

Description: getUsdtTokenAmount relies on an absolute balance check that can be influenced by pre-funding the contract.

Impact: Logic bypass.

Resolution / Team Response: Access-controlled. StakeRole is fully controlled by the team, so the bypass path is not reachable by outsiders.

[BUG-011] YoloToken.initialize Pair-Creation DoS via Pre-Creation**MEDIUM****ACKNOWLEDGED**Affected: **YoloToken.sol**

Description: If the trading pair for the token could be pre-created, initialize() could revert on pair creation, blocking deployment.

Impact: Init DoS.

Resolution / Team Response: Not exploitable. The pair is created at execution time and cannot be pre-created because address(this) (the token address) is only known at deployment.

[BUG-012] Root Inviter Cannot Join Public Referral System**LOW****ACKNOWLEDGED**Affected: **UserManager.sol**

Description: The root inviter is structurally excluded from the public referral tree, a potential cold-start issue.

Impact: Cold-start edge case.

Resolution / Team Response: Accepted. Root inviters are counted starting from the second level, so there is no impact.

[BUG-013] Parent Upgradeable Contracts of CardManager/UserManager Not Initialized**LOW****ACKNOWLEDGED**Affected: **CardManager.sol, UserManager.sol**

Description: Some inherited upgradeable base contracts are not explicitly initialized in the initializer chain.

Impact: Init hygiene.

Resolution / Team Response: Acknowledged; not considered severe.

[BUG-014] ERC-721 NFTs Can Be Permanently Locked in NftTokenManager**MEDIUM****ACKNOWLEDGED**Affected: **NftTokenManager.sol**

Description: NftTokenManager can custody ERC-721 tokens with no path to move them back out, risking permanent lock.

Impact: Asset lock.

Resolution / Team Response: Acknowledged. Contract is upgradeable; a recovery method can be added via upgrade in the future.

[BUG-015] claimRefundingAmount Volume Threshold Bypass via Split Claims**MEDIUM****FIXED**Affected: **UserManager.sol**

Description: The trading-volume gate on claimRefundingAmount could be bypassed by splitting a claim into smaller amounts because volume was not consumed per claim.

Impact: Threshold bypass.

Resolution / Team Response: Fixed. claimRefundingAmount now requires userTradingVolume >= amount * REFUND_CLAIM_MULTIPLIER and decrements userTradingVolume by the claimed amount.

[BUG-016] AMM-Donation Disguised as Liquidity Fully Evades Tax**MEDIUM****OPEN**Affected: **YoloToken.sol**

Description: A transfer disguised as add-liquidity (AMM donation) can be classified so as to completely evade sell fees/fall tax.

Impact: Tax evasion.

Resolution / Team Response: No explicit disposition recorded; pending triage.

[BUG-017] Native ETH Permanently Locked in NftTokenManager**MEDIUM****FIXED**Affected: `NftTokenManager.sol`**Description:** Native ETH received by NftTokenManager had no withdrawal path.**Impact:** Asset lock.**Resolution / Team Response:** Fixed.**[BUG-018] recycle() Pulls Tokens From Pair Without LP Consent, Breaks AMM Invariant****HIGH****ACKNOWLEDGED**Affected: `YoloToken.sol`**Description:** `recycle()` withdraws tokens directly from the trading pair without LP-holder consent, breaking the $x*y=k$ invariant and shifting price.**Impact:** Value transfer from LPs.**Resolution / Team Response:** By design. This is the intended design concept.**[BUG-019] Marking._sellAndRecycle Uses Inflated Input and Wrong Swap Function****MEDIUM****OPEN**Affected: `Marking/TradeSlippage.sol`**Description:** `_sellAndRecycle` passes an inflated input amount and selects the wrong swap function, which can mis-execute the recycle swap.**Impact:** Incorrect swap.**Resolution / Team Response:** No explicit disposition recorded; pending triage.**[BUG-020] Centralized openBuy / openSell Switches -> Honeypot Risk****HIGH****ACKNOWLEDGED**Affected: `YoloToken.sol`**Description:** The owner can toggle `isOpenBuy` / `isOpenSell`, and can disable selling, producing a classic honeypot capability.**Impact:** Honeypot.**Resolution / Team Response:** Intentionally designed.**[BUG-021] usedStakedYoloBalance Never Written -> Permanent Accounting Error****HIGH****ACKNOWLEDGED**Affected: `UserManager.sol`**Description:** `usedStakedYoloBalance` was never assigned, permanently corrupting staking accounting.**Impact:** Accounting corruption.**Resolution / Team Response:** Code updated. The referenced version no longer exists; logic has been rewritten (re-review recommended).

[BUG-022] claimReward Shares fundingBalance Across Reward Types -> Cross-Drain**HIGH**

ACKNOWLEDGED

Affected: `FomoTreasureManager.sol`

Description: claimReward shares a single fundingBalance across reward types, so one reward type can be drained against another's balance.

Impact: Cross-type drain.

Resolution / Team Response: USDT-only. The contract only ever pays USDT rewards; if other tokens are added later the contract will be upgraded to support them.

[BUG-023] updateFundingBalance Inflates Accounting With No Deposit**MEDIUM**

ACKNOWLEDGED

Affected: `FomoTreasureManager.sol` / `CardManager.sol`

Description: updateFundingBalance can increase recorded balances without a corresponding token deposit.

Impact: Accounting inflation.

Resolution / Team Response: By design. Strict permission control; used to bound the amount of funds that can go out.

[BUG-024] _consumeStakeForUsage Consumes Locked Shares Before unlockAt**HIGH**

ACKNOWLEDGED

Affected: `UserManager.sol`

Description: _consumeStakeForUsage could consume locked stake shares before their unlockAt timestamp.

Impact: Premature unlock.

Resolution / Team Response: Code updated. The referenced version no longer exists; logic has been rewritten (re-review recommended).

[BUG-025] bindInviterBatch Parameter Shadows State Variable inviters**LOW**

ACKNOWLEDGED

Affected: `UserManager.sol`

Description: A bindInviterBatch parameter shares the name inviters with a state variable, creating shadowing.

Impact: Shadowing.

Resolution / Team Response: Not an issue per team.

[BUG-026] NftTokenManagerStorage Missing __gap**MEDIUM**

FIXED

Affected: `NftTokenManagerStorage.sol`

Description: The storage contract lacked a __gap reservation, weakening upgrade-storage safety.

Impact: Upgrade safety.

Resolution / Team Response: Fixed. Added uint256[100] private __gap;

[BUG-027] calculateSellAmount / calculateBuyAmount k = rY*rU Overflow Risk**MEDIUM**

OPEN

Affected: `Marking/TradeSlippage.sol`

Description: The product $k = \text{reserveY} * \text{reserveU}$ used in AMM math can overflow for large reserves.

Impact: Overflow.

Resolution / Team Response: No explicit disposition recorded; pending triage.

[BUG-028] CardManager.withdraw No Rollback on Failed Native Transfer

MEDIUM

FIXED

Affected: `CardManager.sol`

Description: withdraw decremented accounting but did not revert on a failed native transfer, desyncing state.

Impact: Accounting desync.

Resolution / Team Response: Fixed. withdraw now require(success, ...) so the transaction reverts and accounting stays consistent.

[BUG-029] CardManager.withdrawErc20 Does Not Decrement fundingBalance

MEDIUM

ACKNOWLEDGED

Affected: `CardManager.sol`

Description: withdrawErc20 does not reduce fundingBalance[tokenAddress].

Impact: Accounting.

Resolution / Team Response: By design. Card-sale tokens do not flow through this logic; this token withdrawal is called by the project party, so fundingBalance[tokenAddress] need not be maintained.

[BUG-030] LpManager / FomoTreasureManager Never Initialize PausableUpgradeable

LOW

ACKNOWLEDGED

Affected: `LpManager.sol`, `FomoTreasureManager.sol`

Description: PausableUpgradeable is inherited but never initialized in these contracts.

Impact: Pause unusable.

Resolution / Team Response: Accepted. No change needed; does not affect funds/safety and these contracts do not need to pause.

[BUG-031] CardManager Redundant ERC721URIStorageUpgradeable Inheritance

INFO

ACKNOWLEDGED

Affected: `CardManager.sol`

Description: CardManager inherits ERC721URIStorageUpgradeable redundantly, adding deployment gas.

Impact: Gas.

Resolution / Team Response: Accepted. Only ~0.000001 BNB extra deploy gas; not worth changing.

[BUG-032] CardManager.depositRewardErc20 Allows Arbitrary feePayer

MEDIUM

ACKNOWLEDGED

Affected: `CardManager.sol`

Description: depositRewardErc20 accepts an arbitrary feePayer, which could pull tokens from any prior approver.

Impact: Approval abuse.

Resolution / Team Response: Deposit-only. This is a top-up (recharge), not a withdrawal, so the described extraction does not apply.

[BUG-033] FomoTreasureManager Native ETH Lock

MEDIUM

FIXED

Affected: `FomoTreasureManager.sol`

Description: Native ETH could be locked in FomoTreasureManager.

Impact: Asset lock.

Resolution / Team Response: Fixed. A receive() function is present.

[BUG-034] FomoTreasureManager.withdrawErc20 Does Not Decrement fundingBalance

MEDIUM

ACKNOWLEDGED

Affected: `FomoTreasureManager.sol`

Description: withdrawErc20 does not reduce fundingBalance for the token.

Impact: Accounting.

Resolution / Team Response: By design. This token withdrawal is called by the project party; fundingBalance is only used for reward distribution.

[BUG-035] CardManager.buyCard / buyCards Bypass Pause Mechanism

LOW

ACKNOWLEDGED

Affected: `CardManager.sol`

Description: buyCard/buyCards are not gated by whenNotPaused.

Impact: Pause bypass.

Resolution / Team Response: By design. Card sales are never paused; there is no emergency-pause requirement for selling.

[BUG-036] UserManager.setYoloToken Breaks Staking Accounting on Migration

MEDIUM

ACKNOWLEDGED

Affected: `UserManager.sol`

Description: Changing the yoloToken address mid-life can break existing staking accounting.

Impact: Migration risk.

Resolution / Team Response: Code is already a new version.

[BUG-037] NFT Metadata URI Immutable; Unrecoverable if IPFS Link Breaks

LOW

ACKNOWLEDGED

Affected: `CardManager.sol` / `NftTokenManager.sol`

Description: NFT URIs are immutable and cannot be repaired if the IPFS link degrades.

Impact: Metadata risk.

Resolution / Team Response: Accepted. NFT images are identical and rarely need changes; can be modified via upgrade if needed.

[BUG-038] Single-Step Ownership Transfer Risk

LOW

ACKNOWLEDGED

Affected: `Multiple`

Description: transferOwnership is single-step; a wrong address transfers ownership irrevocably.

Impact: Ownership loss.

Resolution / Team Response: Accepted. Ownership is transferred only during deployment with verified addresses and post-deploy permission checks.

[BUG-039] Authorized-Caller Update Emits No Event

INFO

ACKNOWLEDGED

Affected: `Multiple`

Description: setContractCaller / authorized-caller updates emit no event.

Impact: Observability.

Resolution / Team Response: Accepted. The team does not need to record this state change on-chain.

[BUG-040] No Generic Rescue for Mistakenly-Sent ERC-20

LOW

OPEN

Affected: Multiple

Description: There is no universal rescue mechanism for ERC-20 tokens sent to the contracts by mistake.

Impact: Stuck tokens.

Resolution / Team Response: No explicit disposition recorded; pending triage.

[BUG-041] distributeReward Unbounded Array Loop -> Block-Gas DoS

MEDIUM

ACKNOWLEDGED

Affected: FomoTreasureManager.sol

Description: distributeReward iterates an unbounded array, which can exceed the block gas limit.

Impact: DoS.

Resolution / Team Response: Off-chain batched. batchSize is controlled by the off-chain caller, so the described DoS does not occur.

[BUG-042] depositRewardErc20 Incompatible With Fee-on-Transfer Tokens

LOW

ACKNOWLEDGED

Affected: CardManager.sol

Description: depositRewardErc20 records the nominal amount, which mismatches actual received amount for fee-on-transfer tokens.

Impact: Accounting.

Resolution / Team Response: Not an issue. Financials are recorded first, users later claim, and tokens are deposited to the contract, so the described problem does not arise.

[BUG-043] bindRootInviter Allows Self-Binding -> Invite-Tree Loop

MEDIUM

ACKNOWLEDGED

Affected: UserManager.sol

Description: bindRootInviter permits self-binding, which could create a cyclic invite tree.

Impact: Infinite loop.

Resolution / Team Response: Access-controlled. Binding is only callable by permissioned accounts and is capped at 16 levels, so the described loop cannot occur.

[BUG-044] _takeSellFee Emits No Event

INFO

ACKNOWLEDGED

Affected: YoloToken.sol

Description: Fee deduction in _takeSellFee is not observable off-chain via events.

Impact: Observability.

Resolution / Team Response: Version updated; the referenced line no longer exists.

[BUG-045] setConfig Does Not Revoke Old Router Approval

LOW

OPEN

Affected: SwapHelper.sol / config

Description: Reconfiguring the router does not revoke the prior router's approval.

Impact: Approval residue.

Resolution / Team Response: No explicit disposition recorded; pending triage.

[BUG-046] claimRefundingAmount Does Not Consume userTradingVolume

MEDIUM

DISPUTED

Affected: `UserManager.sol`

Description: Reviewer reported that claimRefundingAmount does not consume userTradingVolume.

Impact: (disputed).

Resolution / Team Response: Disputed - auditor misunderstanding. Note this overlaps with BUG-015, which was fixed by adding the userTradingVolume decrement.

[BUG-047] validatorMineClaim Permissionless for Any Token -> Drain Risk

HIGH

ACKNOWLEDGED

Affected: `Marking/TradeSlippage.sol`

Description: validatorMineClaim can be called for any token by anyone.

Impact: Drain.

Resolution / Team Response: Balance-guarded. Controlled by validatorBalance[tokenAddress][msg.sender] == amount, which underflows/reverts without a genuine balance.

[BUG-048] getTradeType Precision Loss; Sell Misjudged as Add-Liquidity

MEDIUM

OPEN

Affected: `TradeSlippage.sol`

Description: Decimal mismatch and precision loss in getTradeType can cause a sell to be misclassified as add-liquidity, bypassing fees.

Impact: Misclassification.

Resolution / Team Response: No explicit disposition recorded; pending triage.

[BUG-049] YoloToken.poolAllocate Can Exceed MaxTotalSupply

HIGH

ACKNOWLEDGED

Affected: `YoloToken.sol`

Description: poolAllocate could mint beyond MaxTotalSupply.

Impact: Supply cap breach.

Resolution / Team Response: One-time guarded. Minting can occur only once; subsequent poolAllocate calls revert on the isAllocation == true check, so the cap cannot be exceeded.

[BUG-050] FomoTreasureManager.distributeReward Does Not Verify Token Balance

LOW

ACKNOWLEDGED

Affected: `FomoTreasureManager.sol`

Description: distributeReward does not verify the contract holds enough tokens before distributing.

Impact: Under-funded distro.

Resolution / Team Response: Off-chain verified. Balances are validated off-chain and the call is team-only, so no on-chain restriction is added.

[BUG-051] Flash-Swap Disguises getTradeType, Bypasses isOpenBuy

MEDIUM

ACKNOWLEDGED

Affected: `YoloToken.sol`, `TradeSlippage.sol`

Description: A flash-swap can disguise the trade type to bypass the isOpenBuy lock.

Impact: Lock bypass.

Resolution / Team Response: Known and allowed. Users are permitted to do this.

[BUG-052] FomoTreasureManager / UserManager Pause Function Unreachable**MEDIUM****FIXED**Affected: `FomoTreasureManager.sol`, `UserManager.sol`**Description:** The pause entry points were unreachable.**Impact:** Pause unusable.**Resolution / Team Response:** Fixed.**[BUG-053] Reentry-Lock Gas Optimization (0->1 vs 1->2)****INFO****OPEN**Affected: `Multiple`**Description:** The reentrancy lock could use a 0->1 pattern instead of 1->2 for gas.**Impact:** Gas.**Resolution / Team Response:** No explicit disposition recorded; informational.**[BUG-054] renounceOwnership Can Permanently Disable Protocol Admin****LOW****ACKNOWLEDGED**Affected: `Multiple`**Description:** `renounceOwnership` permanently removes admin capability.**Impact:** Admin loss.**Resolution / Team Response:** Accepted. Renouncing ownership (discarding contract permissions) is a planned end-state and is considered reasonable.**[BUG-055] _distributeSingleReward Missing Zero-Address Check****LOW****FIXED**Affected: `FomoTreasureManager.sol`**Description:** `_distributeSingleReward` did not validate against the zero address.**Impact:** Input validation.**Resolution / Team Response:** Fixed. Added in the new version.**[BUG-056] rewardType Has No Upper-Bound Check****INFO****ACKNOWLEDGED**Affected: `FomoTreasureManager.sol`**Description:** `rewardType` lacked an explicit upper-bound check.**Impact:** Input validation.**Resolution / Team Response:** Enum-bounded. The enum type constrains valid values.**[BUG-057] TradeSlippage.getTradeType Multi-Hop Semantics Unclear****INFO****ACKNOWLEDGED**Affected: `TradeSlippage.sol`**Description:** `getTradeType` semantics for multi-hop trading pairs are unclear.**Impact:** Clarity.**Resolution / Team Response:** Accepted. Behavior matches the contract's intent.

[BUG-058] bindInviterBatch / updateUserTradingVolume Unbounded Loop**MEDIUM****ACKNOWLEDGED**Affected: **UserManager.sol****Description:** Both functions iterate unbounded input arrays.**Impact:** DoS.**Resolution / Team Response:** Off-chain controlled. Backend binding logic bounds the input size.**[BUG-059] Redundant allowance / balanceOf Checks Before safeTransferFrom****INFO****ACKNOWLEDGED**Affected: **Multiple****Description:** Explicit allowance/balanceOf checks precede safeTransferFrom redundantly.**Impact:** Gas / redundancy.**Resolution / Team Response:** Accepted. allowance is an authorization check and balanceOf is a balance check; considered minor.**[BUG-060] withdraw Unnecessarily payable -> ETH Mis-Send Loss****LOW****FIXED**Affected: **CardManager.sol****Description:** A withdraw function was marked payable without needing to be, risking mistakenly-sent ETH.**Impact:** Mis-send.**Resolution / Team Response:** Fixed.**[BUG-061] Inconsistent Solidity Pragma Versions****INFO****FIXED**Affected: **Multiple****Description:** Pragma versions were inconsistent across files.**Impact:** Consistency.**Resolution / Team Response:** Fixed.**[BUG-062] Dead State Variable in YoloTokenStorage****INFO****ACKNOWLEDGED**Affected: **YoloTokenStorage.sol****Description:** A state variable in YoloTokenStorage is unused.**Impact:** Code quality.**Resolution / Team Response:** Accepted as a code-style matter.**[BUG-063] adminFeeVault Unused in CardManagerStorage****INFO****ACKNOWLEDGED**Affected: **CardManagerStorage.sol****Description:** adminFeeVault is declared but unused.**Impact:** Code quality.**Resolution / Team Response:** Removed in the current version.

[BUG-064] TradeSlippage.isContract Unreliable During Construction

LOW

ACKNOWLEDGED

Affected: `TradeSlippage.sol`

Description: isContract can be unreliable during a contract's construction.

Impact: Detection edge case.

Resolution / Team Response: Not applicable. By the time it is used the contract is already deployed.

[BUG-065] Commented-Out Transfer Restriction in CardManager

INFO

ACKNOWLEDGED

Affected: `CardManager.sol`

Description: A transfer restriction is commented out.

Impact: Dead code.

Resolution / Team Response: No longer present in the current version.

[BUG-066] NftTokenManager.setWithdrawCaller Allows address(0)

LOW

FIXED

Affected: `NftTokenManager.sol`

Description: setWithdrawCaller accepted address(0), which could permanently disable withdrawals.

Impact: Config error.

Resolution / Team Response: Fixed. Zero-address guard added.

[BUG-067] _autoFuckExternal Is external; ABI Exposure and Naming

LOW

OPEN

Affected: `YoloToken.sol`

Description: An internal-intent function is external, exposing it in the ABI, with an unprofessional name.

Impact: ABI hygiene.

Resolution / Team Response: No explicit disposition recorded; pending triage.

[BUG-068] setPlatformAddress Duplicates setFomoTreasureAddress

INFO

FIXED

Affected: `YoloToken.sol`

Description: setPlatformAddress duplicates setFomoTreasureAddress.

Impact: Redundancy.

Resolution / Team Response: Fixed.

[BUG-069] UserManager.initialize Unnamed/Unused Second Parameter

INFO

FIXED

Affected: `UserManager.sol`

Description: initialize had an unnamed, unused second parameter.

Impact: Code quality.

Resolution / Team Response: Fixed in the current version.

[BUG-070] CardManager Has Two ETH Receive Paths

INFO

ACKNOWLEDGED

Affected: **CardManager.sol**

Description: CardManager exposes two ETH receive paths (logical redundancy).

Impact: Redundancy.

Resolution / Team Response: Accepted; does not affect behavior.

[BUG-071] SPORTS_USAGE_BPS Constant Unused

INFO

ACKNOWLEDGED

Affected: **Multiple**

Description: The SPORTS_USAGE_BPS constant is unused.

Impact: Dead constant.

Resolution / Team Response: Acknowledged.

[BUG-072] isSwapFactory Wastes Gas via Self-External Call

INFO

ACKNOWLEDGED

Affected: **TradeSlippage.sol**

Description: isSwapFactory makes an external call to itself, wasting gas.

Impact: Gas.

Resolution / Team Response: Accepted. Used when external parties need to verify data.

[BUG-073] Unused view Function in YoloToken

INFO

ACKNOWLEDGED

Affected: **YoloToken.sol**

Description: An unused view function exists in YoloToken.

Impact: Dead code.

Resolution / Team Response: Acknowledged; no change.

[BUG-074] Redundant _transferOwnership in YoloToken.initialize

INFO

ACKNOWLEDGED

Affected: **YoloToken.sol**

Description: _transferOwnership call in initialize is redundant.

Impact: Redundancy.

Resolution / Team Response: Acknowledged; no change.

[BUG-075] _batchCardPrice Nested Loops Re-Read Storage

INFO

ACKNOWLEDGED

Affected: **CardManager.sol**

Description: _batchCardPrice re-reads storage inside nested loops.

Impact: Gas.

Resolution / Team Response: Accepted. Per-user NFT purchase counts are small, so efficiency is adequate.

[BUG-076] CardManager.setContractCaller Inaccurate Error Message

INFO

FIXED

Affected: `CardManager.sol`

Description: The setContractCaller error message is inaccurate.

Impact: Message.

Resolution / Team Response: Fixed.

[BUG-077] PausableUpgradeable Unused in LpManager

INFO

ACKNOWLEDGED

Affected: `LpManager.sol`

Description: PausableUpgradeable is inherited but unused in LpManager.

Impact: Dead inheritance.

Resolution / Team Response: Acknowledged; no change.

[BUG-078] FomoTreasureManager Error Message Cites Wrong Contract Name

INFO

FIXED

Affected: `FomoTreasureManager.sol`

Description: An error message references the wrong contract name.

Impact: Message.

Resolution / Team Response: Fixed.

[BUG-079] TradeSlippage owner Uninitialized -> Admin Funcs Unusable

LOW

ACKNOWLEDGED

Affected: `TradeSlippage.sol`

Description: owner is never initialized, so admin functions are permanently unusable.

Impact: Admin unusable.

Resolution / Team Response: Acknowledged; no change (admin functions not required in current use).

[BUG-080] Marking Uses Handwritten Reentry Lock, Not OZ Guard

INFO

ACKNOWLEDGED

Affected: `Marking/TradeSlippage.sol`

Description: Marking uses a handwritten reentrancy lock rather than OZ ReentrancyGuardUpgradeable.

Impact: Convention.

Resolution / Team Response: Acknowledged; no change.

[BUG-081] CardManager minAmount Hardcodes 18-Decimal Precision

LOW

ACKNOWLEDGED

Affected: `CardManager.sol`

Description: minAmount hardcodes 18-decimal precision, which would misprice cards under a 6-decimal token.

Impact: Precision assumption.

Resolution / Team Response: Not applicable. underlyingToken is USDT on BNB Chain, which uses 18 decimals.

Economic & Tokenomics Analysis

Intentional adversarial mechanics. BUG-001, BUG-002, BUG-018, BUG-020 and BUG-051 are confirmed by the team as deliberate. They are protective of the protocol treasury but adversarial toward ordinary holders: an oracle-timed fall tax, a flash-loan path that advantages sophisticated actors, a `recycle()` that transfers value away from LPs, and honeypot-capable buy/sell switches. A security reader would otherwise flag these as rug-enabling — they should be **clearly disclosed to users**.

Centralization. The `contractCaller` and owner are central points of failure. Reward printing, market/price actions, and fund movement all assume these keys are secure; the accepted-risk findings collapse if either key is compromised.

Final Recommendations

- **Governance hardening (highest priority):** place owner and `contractCaller` behind a multisig + timelock; emit events on every privileged state change (addresses BUG-039, BUG-044); adopt two-step ownership transfer (BUG-038); publish the trust model and the `renounceOwnership` policy (BUG-054).
- **Disclose intentional mechanics** (BUG-001/002/018/020/051) prominently to users.
- **Triage the open items** before mainnet — especially BUG-027 (AMM multiplication overflow) and BUG-048 (precision/trade-type misclassification), plus BUG-016, BUG-019, BUG-040, BUG-045, BUG-053, BUG-067.
- **Re-audit the rewritten staking code** that supersedes BUG-021 / BUG-024, and confirm BUG-015 / BUG-046 are consistent against the current tree.
- **Enforce the single-reward-token assumption in code** so BUG-022 cannot regress on a future multi-token upgrade.
- **Defense-in-depth:** revoke old router approval on `setConfig` (BUG-045) and reset approvals in `SwapHelper` (BUG-008).

Conclusion

The confirmed, exploitable defects raised during the review have been remediated (16 fixed). The remaining posture is a deliberately centralized, tokenomics-driven design whose safety is contingent on the stated trust assumptions and on the open items above being triaged before deployment. Findings marked “code updated” require re-review against the current source.

Disclaimer: This report reflects the state of the code and the team's responses as reconciled at the report date. It is not a guarantee of the absence of vulnerabilities. Accepted-risk items remain the responsibility of the project team and its users under the stated trust assumptions.